

TOOLLAW

GOAI 2026 · Track 1 Agent Infra · Accra Technical University · 2026-08-14

Sources: GOAI handbook · goaihz.com · AgentTeams (formerly HiClaw) · T1 lock (not demo 4 / not PROOFLOOP)

One sentence. Agent Infra for tools: an AgentTeams crew that compiles who may call which Skill or MCP tool, with which args, into a fail-closed allowlist. Policy Compiler writes the artifact; Red Team must lose in the Matrix room; Gateway Auditor proves the forbidden call did not execute and emits hashed evidence.

Prelim does not require runnable code. Semi-final (2026-09-03) ships an AgentTeams demo. Not a trading bot. Not handbook Direction 1 ITSM. Not AgentTeams demo 4 incident chat.

1. Scenario and value (25%)

Problem. OSS agent gateways typically ACL at **server** level. A Worker allowed to talk to an MCP server can still fire the wrong **tool** with the wrong **args**. OpenTelemetry traces show the blast after it happens. Enterprises need enforcement: AppArmor / IAM for agent tools.

Users. Platform, SRE, and security teams running multi-agent fleets. Not retail chat users. Not traders.

Value. Compiled tool-level law + red-team proof + hashed receipts. Replicable: swap fixture JSON; keep roles, Skills, and default BLOCK.

Not this idea. Nacos+Higress logo stack; LangGraph SRE crew ported to AgentTeams; official demo 4 with a new fixture name.

2. Solution

TOOLLAW makes “who may call which tool with which args” a **Skill**, then proves it. Lived halt / redeem / env-mix events are an **attack pack**, not the pitch. Moat line: *Traces show what happened. TOOLLAW decides what is allowed to happen.*

3. Multi-agent closed loop (25%)

Baseline: AgentTeams Manager–Workers in a Matrix room. Humans are first-class members (L3 on high-risk). Four named roles plus Human.

Step	Who	AgentTeams mapping
Task input	Red Team	Worker posts fixture JSON as a ToolLaw attempt
Decomposition	Manager + Policy Compiler	TeamHarness assigns compile vs attack vs audit
Context passing	Shared ToolLaw object	Files / artifacts, not a 20k-token chat dump
Tool calling	Skills + MCP-shaped catalog	Gateway holds secrets (Higress pattern)
Result verification	Auditor	executed: false on BLOCK; ALLOW on health read
Evidence	Auditor	policyHash + sha256 receipt
Approval / rollback	Human L3	No ticket → BLOCK (prevent, not undo)
Experience capture	Auditor	Writes reusable toollaw.deny-unhalt

Exception branches. Unknown tool → BLOCK. Peer path in env args → BLOCK. Unsettled redeem → BLOCK. Red Team calling approve → BLOCK. Compiler error → BLOCKED, do not load stale policy.

4. Agent identity list (Appendix A)

ID	Role	AgentTeams	May	Must not
mgr	Manager	Manager	Create Team, track state	Fire tools
pol	Policy Compiler	Leader or Worker	Compile YAML → allowlist	Execute risky tools
red	Red Team	Worker	Attack with forbidden Skills	Self-approve
aud	Gateway Auditor	Worker	Match traces, evidence	Weaken allowlist
hum	Human	Matrix Human	ALLOW / DENY	Be optional on high-risk

State machine: OPEN → COMPILING → ATTACKING → BLOCKED | AWAITING_APPROVAL → VERIFYING → CLOSED.

5. Skills (mandatory, 25%)

Skill is the task-capability abstraction. MCP (or equivalent contract) is the tool-connection layer. Specs live in skills/. Handbook: Skill mandatory; MCP recommended.

Skill	Purpose	I/O (summary)	Mutate	Approval
toollaw.compile	Hash allowlist artifact	policy → policyHash	artifact	no
toollaw.enforce	Deterministic gate	attempt → ALLOW/BLOCK/REQUIRE_APPROVAL	no	n/a
toollaw.redteam	Submit attack fixture	fixtureId → ToolLaw attempt	attempt only	must fail closed
toollaw.evidence	Append-only receipt	ToolLaw → uri + sha256	evidence	no
toollaw.approve	Human L3 ticket	ALLOW/DENY → ticketId	ticket	human-only
toollaw.health	Read fixture	agent → synthetic health	no	no
toollaw.deny-unhalt	Capture after BLOCK	receipt → deny Skill	no	n/a

Attack surface (fixtures, not product Skills): fixture.unhalt, fixture.redeem, fixture.env.patch. Never pointed at production /opt/scout or /opt/lockin.

6. Engineering / audit (20%) and OSS (5%)

Typed JSON Schema for the ToolLaw object and compiled policy. Default fail-closed. Evidence zip for judges. Apache-2.0. No secrets in git.

Higress OSS vs Enterprise tool-level ACL is documented as a product gap in HiClaw 1.0.6 materials (TinyFish/GitHub). Tavily did not fully prove the split — we mark it partial and still close the gap with Skills.

7. Demo plan (3 Sep, same loop 22–23 Sep Hangzhou)

Red Team fires high-risk Skill → BLOCK + receipt → Human ALLOW on toolaw.health → peer-fleet env patch BLOCK → Auditor zip. Kill beat: Red Team cannot stamp its own ticket.

8. Honest limits

This idea does not guarantee Top 15. Prelim is scored on completeness and scenario. Semi requires a runnable AgentTeams fail-closed loop. Aliyun: a small evidenced loop beats a fake platform.